

Tài liệu đặc tả kiến trúc hệ thống

1. Tổng quan tài liệu

1.1. Mục đích tài liệu

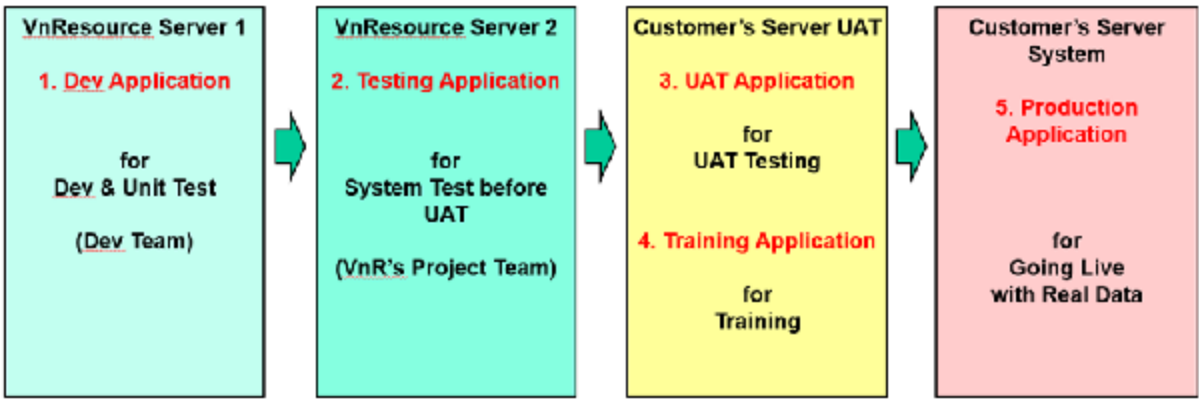
- ▶ Tài liệu này mô tả chi tiết kiến trúc tổng thể của hệ thống nhằm:
 - ▶ Làm rõ cách tiếp cận về mặt công nghệ, thiết kế kỹ thuật;
 - ▶ Chứng minh khả năng đáp ứng yêu cầu kỹ thuật của bên mời thầu;
 - ▶ Làm căn cứ triển khai, kiểm thử và bảo trì hệ thống.
- ▶ Tài liệu này cung cấp cho các đối tượng người dùng (kinh doanh, triển khai, khách hàng, ...) có cái nhìn tổng quan nhất về các chức năng của hệ thống.

1.2. Các khái niệm, thuật ngữ

#	Thuật ngữ/ Từ viết tắt	Ý nghĩa
	VNR	Công ty cổ phần Tài nguyên Tri thức Việt Năng (VnResource)

2. Mô hình triển khai

Hệ thống HRM có thể được triển khai theo hai mô hình chính tùy theo nhu cầu khách hàng: **On-Premise** (tại chỗ) hoặc **On-Cloud** (đám mây). Mỗi mô hình có kiến trúc triển khai, ưu nhược điểm và điều kiện áp dụng khác nhau. Dưới đây là mô tả chi tiết cho từng mô hình, cùng với phương án mở rộng hệ thống và kiến trúc đảm bảo High Availability (HA) và Load Balancing (cân bằng tải).

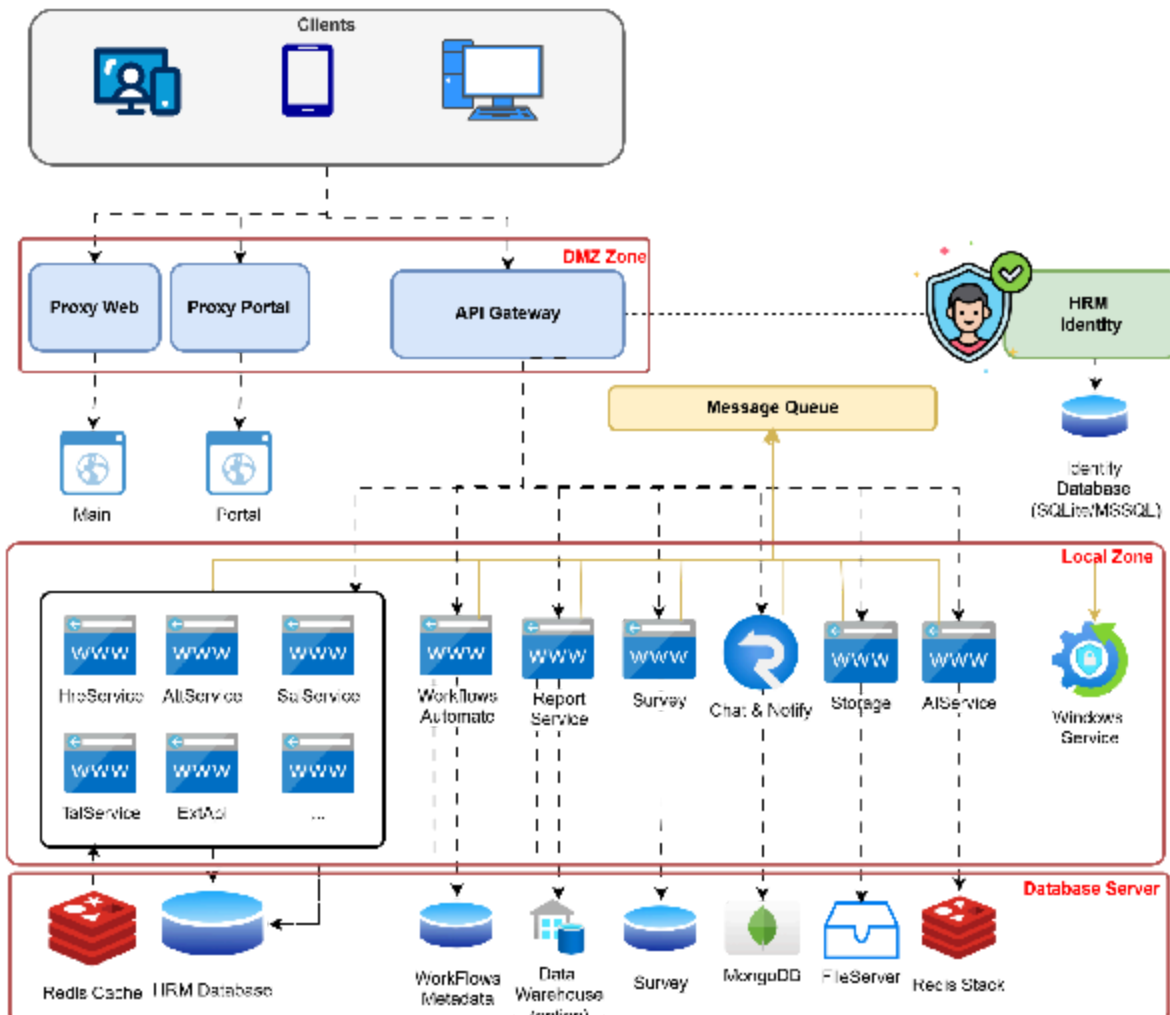


Deployment system includes 4 server system environments with 4 steps to deploy:

- Step 1: If any customization, VnResource's Developer team customize and unit-test on Dev Application Server Environment (server 1 at VnResource site).
- Step 2: Deployment Team configure the system and test on server 2 at VnResource site.
- Step 3: VnResource team will deploy on Customer's UAT Server for User acceptance test. This server is necessary, if customer could not invest this server, both parties discuss to have the best solution to ensure the quality of project before transport to Production Application.
- Step 4: Transport to Production Application and keep the production system stable.

2.1. Kiến trúc tổng quan

Hệ thống phần mềm Quản Lý Nhân Sự của VnResource sử dụng các công nghệ và kiến trúc hiện đại để đảm bảo hiệu suất, độ tin cậy, và khả năng mở rộng. Dưới đây là tổng quan về kiến trúc hệ thống:



Hình 1 Tổng quan kiến trúc

Công nghệ sử dụng

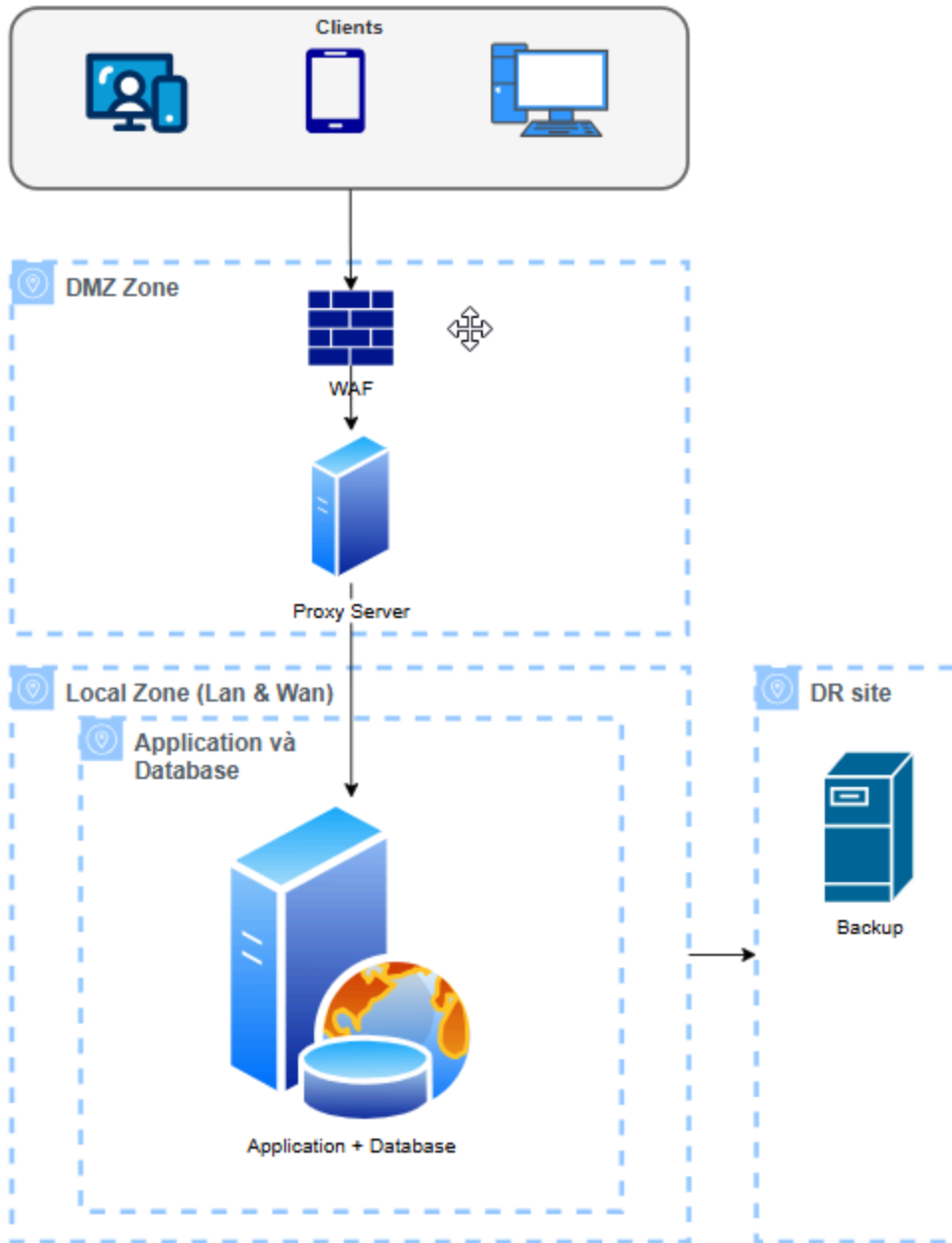
Thành phần	Công nghệ	Mô tả
Frontend	Angular 19	Framework web hiện đại dùng để phát triển giao diện người dùng (UI). Angular 19 hỗ trợ hiệu suất cao, cấu trúc rõ ràng, tương thích đa trình duyệt và dễ bảo trì.
Backend	.Net 8	Nền tảng backend mạnh mẽ của Microsoft, hỗ trợ phát triển các API RESTful, xử lý logic nghiệp vụ, bảo mật và hiệu suất cao. Phiên bản .NET 8 hỗ trợ đa nền tảng và cải tiến đáng kể về tốc độ.
Database	SQL Server / PostgreSQL	Hệ quản trị cơ sở dữ liệu quan hệ được sử dụng để lưu trữ dữ liệu nhân sự, chấm công, lương, tuyển dụng,... Hỗ trợ cơ chế backup, HA, phân quyền và truy vấn hiệu quả.
File Server	Network File System	Lưu trữ các file đính kèm như hợp đồng lao động, hồ sơ nhân viên, biểu mẫu,... Hệ thống hỗ trợ truy cập qua mạng nội bộ, phân quyền và đồng bộ.
API Gateway	Ocelot	Là gateway quản lý luồng API giữa frontend và backend. Hỗ trợ routing, load balancing, xác thực token, và logging. Ocelot đặc biệt phù hợp với kiến trúc microservices trong môi trường .NET.
Authentication	OAuth2 / OpenID Connect	Cơ chế xác thực hiện đại và an toàn. Hỗ trợ đăng nhập một lần (SSO), phân quyền chi tiết, và mở rộng xác thực đa yếu tố (MFA) nếu cần. Thích hợp cho môi trường tích hợp nhiều hệ thống.

2.2 Mô hình triển khai On-Premise

Mô hình On-Premise là hình thức cài đặt toàn bộ hệ thống HRM trên máy chủ và hạ tầng CNTT nội bộ của doanh nghiệp hoặc Datacenter bên ngoài. Hệ thống bao gồm các thành phần như máy chủ ứng dụng (chạy backend .NET và API), máy chủ web (frontend Angular), máy chủ cơ sở dữ liệu (SQL Server) và các dịch vụ phụ trợ khác,

Điều kiện triển khai: Mô hình On-Premise phù hợp với các doanh nghiệp đã có sẵn hạ tầng máy chủ và yêu cầu cao về việc dữ liệu phải nằm tại nội bộ (ví dụ: yêu cầu tuân thủ chính sách bảo mật nội bộ hoặc quy định pháp luật về dữ liệu). Doanh nghiệp cần có phòng máy đảm bảo nguồn điện, máy lạnh, firewall bảo vệ, và đội ngũ kỹ thuật vận hành.

2.2.1. Mô hình 1: Mô hình cơ bản



Mô hình này là một kiến trúc mạng và hệ thống ứng dụng phân lớp, được thiết kế để đảm bảo an toàn và quản lý lưu lượng truy cập từ các thiết bị client đến ứng dụng và cơ sở dữ liệu. Cụ thể như sau:

► **Clients (Khách hàng)**

Đây là các thiết bị người dùng cuối có thể là điện thoại di động, máy tính bảng hoặc máy tính để bàn. Người dùng truy cập hệ thống thông qua các thiết bị này.

► **DMZ Zone (Vùng DMZ)**

► **WAF (Web Application Firewall - Tường lửa ứng dụng web):**

Đây là lớp bảo vệ đầu tiên chống lại các cuộc tấn công từ bên ngoài, lọc và kiểm tra các yêu cầu đến hệ thống.

► **Proxy Server (Máy chủ proxy):**

Là lớp trung gian tiếp nhận các yêu cầu từ WAF, chuyển tiếp các yêu cầu hợp lệ đến tầng bên trong (Local Zone). Proxy cũng có thể thực hiện các chức năng như cache, kiểm soát truy cập và cân bằng tải.

- ▶ **Local Zone (Vùng mạng nội bộ - LAN & WAN)**

Đây là vùng mạng an toàn bên trong hệ thống, không trực tiếp kết nối với bên ngoài mà phải qua DMZ.

- ▶ **Server Application + Database (Ứng dụng và Cơ sở dữ liệu):**

Máy chủ ứng dụng chính (Web/API Server) xử lý nghiệp vụ HRM.

- ▶ Máy chủ cơ sở dữ liệu SQL Server lưu trữ toàn bộ dữ liệu nhân sự.

- ▶ Backup định kỳ và giám sát chặt chẽ.

- ▶ Được cô lập trong mạng nội bộ, chỉ cho phép kết nối từ Proxy đã xác thực.

- ▶ **DR Site (Disaster Recovery Site)**

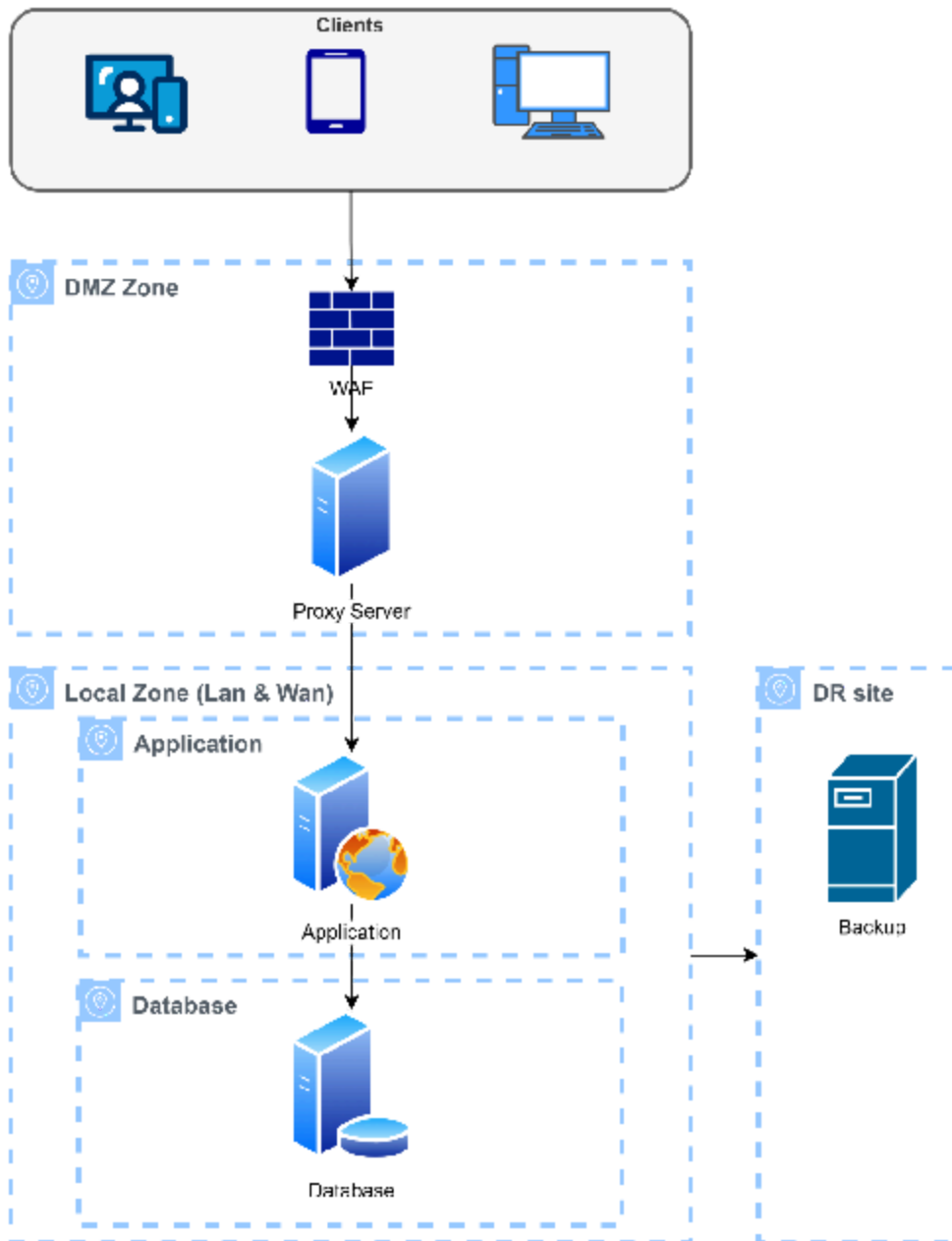
- ▶ Máy chủ DR nằm ở vị trí địa lý khác (off-site).

- ▶ Lưu trữ định kỳ với database, file, mã nguồn ứng dụng chính.

- ▶ Sẵn sàng thay thế khi hệ thống chính gặp sự cố lớn như cháy nổ, mất điện diện rộng.

2.1.2. Mô hình 1: Mô hình tiêu chuẩn

Mô hình kiến trúc 3 tầng (Three-Tier Architecture) với dự phòng và phân vùng bảo mật – phù hợp cho hệ thống có lưu lượng trung bình và yêu cầu bảo mật cao.



Hình 2 Mô hình kiến trúc chuẩn

► **Clients (Người dùng đầu cuối)**

- Bao gồm nhân viên, quản lý, bộ phận nhân sự truy cập hệ thống qua máy tính, điện thoại, máy tính bảng.
- Truy cập qua trình duyệt hoặc ứng dụng mobile

► **DMZ Zone (Demilitarized Zone)**

- Proxy Server nằm tại vùng DMZ, chịu trách nhiệm tiếp nhận tất cả các kết nối từ bên ngoài (Internet hoặc WAN).
- Là điểm kiểm soát đầu tiên để kiểm tra, lọc, chống tấn công từ Internet (ví dụ: tấn công DDoS, Injection).
- Giao tiếp với tầng ứng dụng bên trong, giới hạn quyền truy cập.

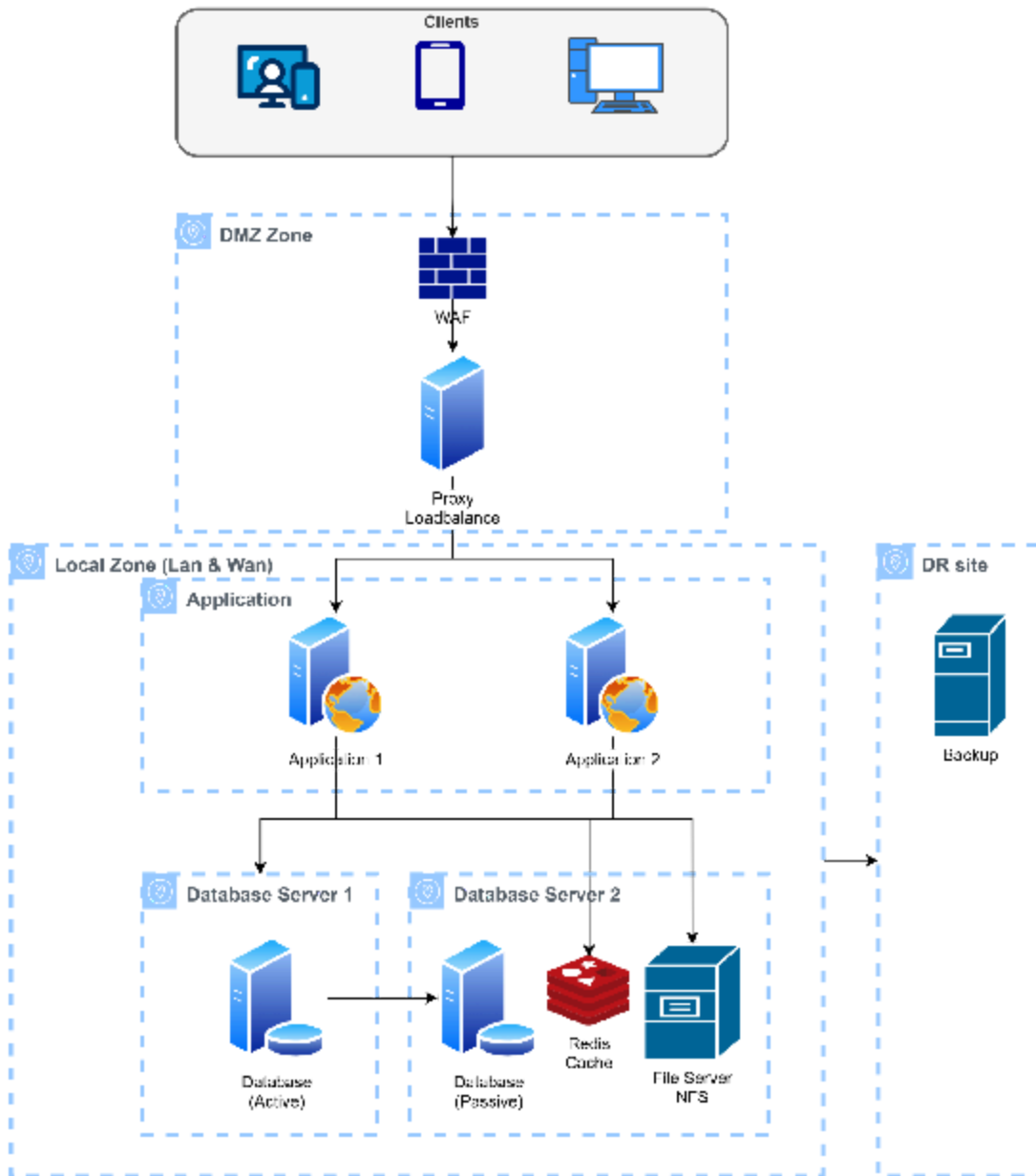
► **Local Zone (LAN & WAN nội bộ)**

- **Application Zone:**

- Máy chủ ứng dụng chính (Web/API Server) xử lý nghiệp vụ HRM.
- Được cô lập trong mạng nội bộ, chỉ cho phép kết nối từ Proxy đã xác thực.
- **Database Zone:**
 - Máy chủ cơ sở dữ liệu SQL Server lưu trữ toàn bộ dữ liệu nhân sự.
 - Backup định kỳ và giám sát chặt chẽ.
- **DR Site (Disaster Recovery Site)**
 - Máy chủ DR nằm ở vị trí địa lý khác (off-site).
 - Lưu trữ định kỳ với database, file, mã nguồn ứng dụng chính.
 - Sẵn sàng thay thế khi hệ thống chính gặp sự cố lớn như cháy nổ, mất điện diện rộng.

3. Mô hình 2: Mô hình mở rộng

Mô hình mở rộng cho quy mô lớn hơn, đáp ứng HA (High Availability)



Hình 3 Mô hình mở rộng hiệu suất cao

► **Clients**

- Người dùng gồm nhân viên, lãnh đạo, bộ phận nhân sự truy cập từ nhiều thiết bị: desktop, mobile, tablet.
- Truy cập thông qua Internet hoặc VPN, đi qua server proxy.

► **DMZ Zone**

- **Proxy Load Balancer** là điểm tiếp nhận đầu vào, thực hiện cân bằng tải lưu lượng đến các máy chủ ứng dụng.
- Được bảo vệ bởi firewall và giới hạn truy cập theo IP/domain tin cậy.
- Giúp giảm tải và bảo vệ các ứng dụng phía trong khỏi tấn công trực tiếp từ Internet.

► **Local Zone (LAN & WAN)**

- Application Zone

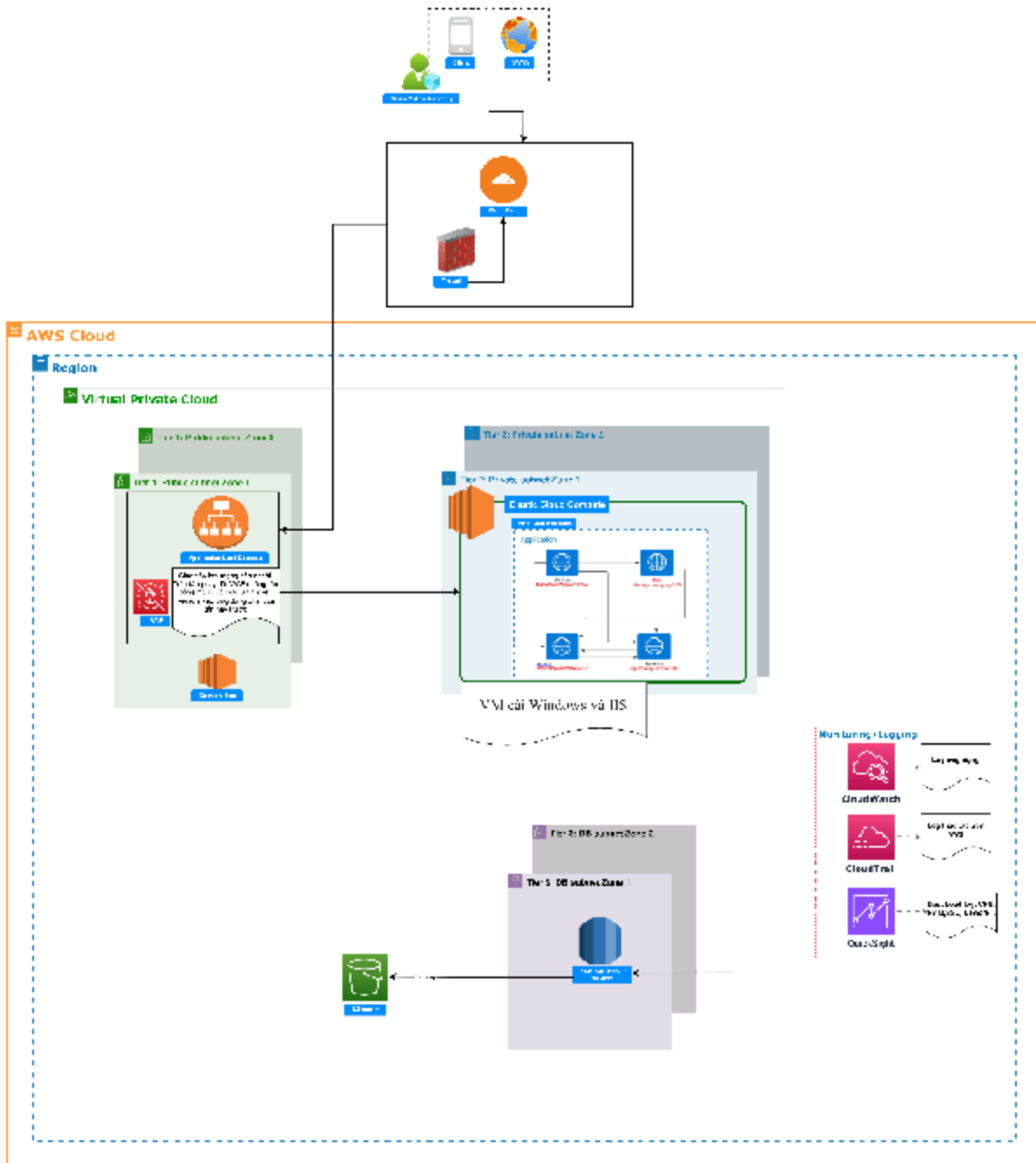
- Gồm nhiều máy chủ ứng dụng (Application 1, Application 2).
- Được đặt sau load balancer và đảm bảo khả năng mở rộng dễ dàng.
- Ứng dụng có thể triển khai dạng container hoặc máy ảo, cho phép scale-out theo tải sử dụng.
- Database Zone
 - Đảm bảo tính sẵn sàng cao - HA (High Availability) sử dụng Always On Availability Groups (AG)
 - Database Server 1 (Active): node chính xử lý mọi giao dịch.
 - Database Server 2 (Passive): node phụ đồng bộ real time replication.
 - **Redis Cache** được thêm vào để giảm tải truy vấn trực tiếp đến SQL Server – lưu tạm dữ liệu thường dùng như danh mục, cấu hình, truy vấn phổ biến.
- **DR Site**
 - Trung tâm dữ liệu dự phòng đặt tại site thứ hai, vật lý tách biệt.
 - Sao lưu định kỳ toàn bộ hệ thống và dữ liệu.
 - Khi xảy ra sự cố nghiêm trọng (cháy, mất điện, thiên tai), hệ thống có thể **chuyển sang DR site** hoạt động trong vài giờ.

2.2. Mô hình triển khai On-Cloud

Mô hình On-Cloud là hình thức triển khai hệ thống HRM trên hạ tầng điện toán đám mây của nhà cung cấp (ví dụ: Microsoft Azure, AWS, hoặc hạ tầng cloud tư nhân). Toàn bộ ứng dụng (frontend, backend, cơ sở dữ liệu) được cài đặt trên các máy chủ ảo hoặc dịch vụ nền tảng đám mây. Người dùng truy cập hệ thống thông qua Internet (trình duyệt web) từ bất kỳ địa điểm nào.

2.2.1. Mô hình On-Cloud với kiến trúc AWS Single-Tenant

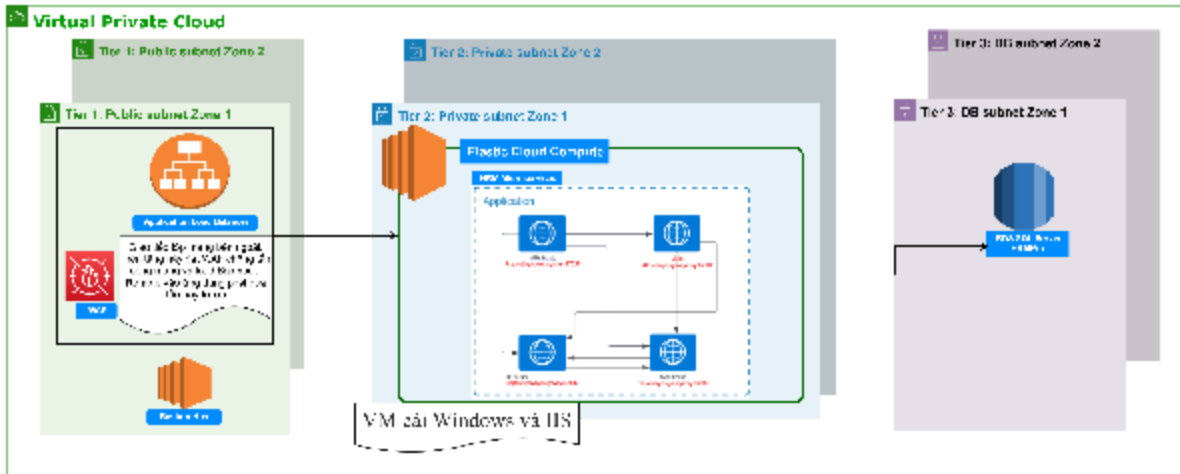
Hệ thống HRM được triển khai trên nền tảng **AWS Cloud** với kiến trúc **Single-Tenant Isolation**, đảm bảo rằng toàn bộ tài nguyên sử dụng (máy chủ, dữ liệu, mạng) được tách biệt hoàn toàn giữa các khách hàng.



Hình 4 Mô hình On-Cloud với kiến trúc AWS Single Tenant ([Xem chi tiết](#))

Mô hình gồm 3 tầng mạng chính (3-tier subnet model):

- ▶ **Tầng công cộng (Public subnet)** để tiếp nhận truy cập từ Internet
- ▶ **Tầng ứng dụng (Private Application subnet)** để xử lý nghiệp vụ
- ▶ **Tầng cơ sở dữ liệu (DB subnet)** đảm bảo cách ly và bảo mật dữ liệu nhân sự



Hình 5 Chi tiết Virtual Private Cloud và các thành phần trong mỗi tầng

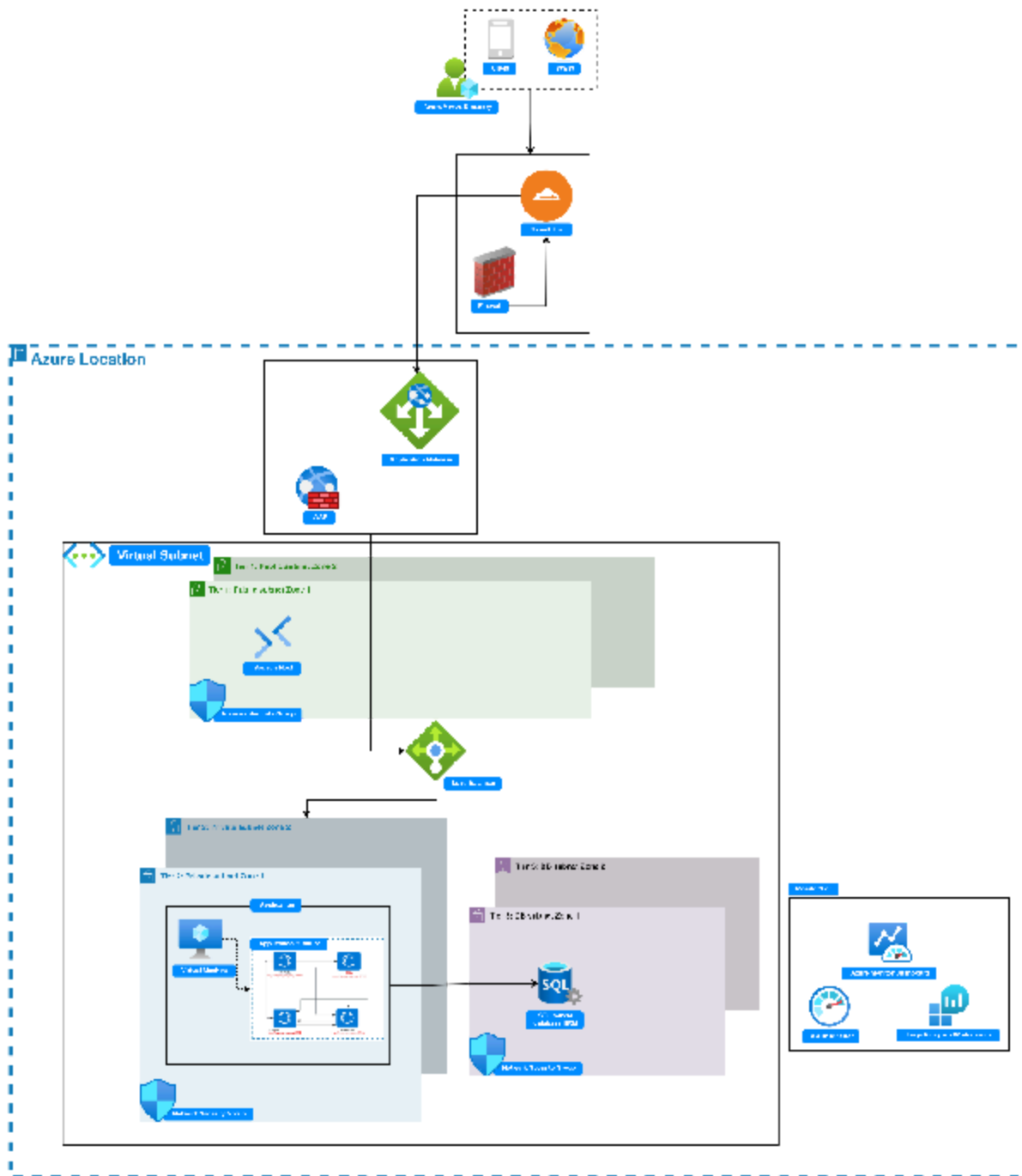
Chi tiết mô hình gồm các thành phần:

- ▶ **Bảo mật đầu vào**
- ▶ Toàn bộ truy cập từ Internet đi qua **Cloudflare** (CDN + bảo vệ tấn công DDoS) → sau đó đến **Application Load Balancer (ALB)**.
- ▶ ALB tích hợp **Web Application Firewall (WAF)** giúp chặn tấn công tầng ứng dụng như SQL Injection, Cross-Site Scripting (XSS), v.v.
- ▶ Truy cập từ kỹ thuật viên (DevOps) phải thông qua **Bastion Host**, kiểm soát theo IP và chính sách VPN nghiêm ngặt.
- ▶ **Tầng ứng dụng (Elastic Cloud Compute)**
 - ▶ Các máy chủ ứng dụng được triển khai trên **EC2 Instance** – cài hệ điều hành Windows + IIS để chạy hệ thống HRM (backend .NET và frontend Angular).
 - ▶ Có thể triển khai dạng **microservices** theo từng chức năng như Quản lý nhân sự, chấm công, tính lương...
 - ▶ Giao tiếp nội bộ giữa các dịch vụ qua Private IP; không có thành phần nào của tầng ứng dụng công khai ra ngoài.
- ▶ **Tầng cơ sở dữ liệu (Database Layer)**
 - ▶ Dữ liệu nhân sự được lưu trữ trên **Amazon RDS – SQL Server**, nằm trong DB Subnet (Private Zone) với chế độ mã hóa dữ liệu (Encryption at rest).
 - ▶ Hệ thống tự động backup dữ liệu định kỳ và hỗ trợ khôi phục tức thời (point-in-time recovery).
 - ▶ Đảm bảo **HA (High Availability)** với cơ chế Multi-AZ replication (tự động nhân bản sang Availability Zone khác để sẵn sàng phục hồi).
- ▶ **Dịch vụ lưu trữ và sao lưu**
 - ▶ Tài liệu nhân sự, tệp đính kèm được lưu trữ trên **Amazon S3** với phân quyền truy cập rõ ràng.
 - ▶ Tự động đồng bộ và lưu trữ lâu dài (lifecycles) – dễ khôi phục khi cần.
- ▶ **Giám sát & Nhật ký hệ thống**
 - ▶ **CloudWatch**: Thu thập log ứng dụng, cảnh báo khi có bất thường (CPU, RAM, lỗi truy cập...).

- **CloudTrail:** Ghi lại thao tác quản trị hệ thống (ai thao tác gì, lúc nào).
- **QuickSight:** Trực quan hóa log, dashboard hiệu suất và truy cập hệ thống.
- **Khả năng mở rộng & linh hoạt**
 - Có thể mở rộng **ngang** số lượng EC2 khi lưu lượng tăng (thêm node ứng dụng).
 - Có thể scale theo chức năng nếu chuyển sang mô hình **Microservices** hoàn toàn.
 - Mọi tài nguyên đều có thể **giám sát theo thời gian thực** và mở rộng theo nhu cầu sử dụng.

2.2.2. Mô hình On-Cloud với kiến trúc AZURE Single Tenant

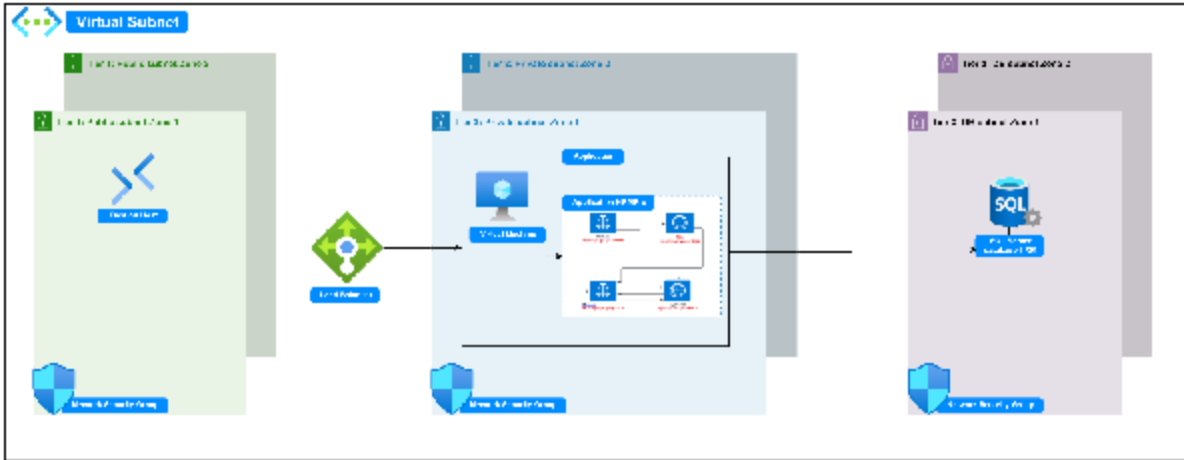
Hệ thống HRM được triển khai trên hạ tầng **Microsoft Azure**, sử dụng kiến trúc **Single-Tenant** và mô hình mạng phân tầng 3 lớp (3-tier architecture), giúp tách biệt các vai trò: tiếp nhận truy cập, xử lý nghiệp vụ, và lưu trữ dữ liệu. Mỗi khách hàng có hạ tầng riêng biệt nhằm đảm bảo **bảo mật và khả năng tùy chỉnh độc lập**.



Hình 6 Mô hình On-Cloud với kiến trúc AZURE Single Tenant ([Xem chi tiết](#))

Kiến trúc khi triển khai trên Azure cũng bao gồm 3 tầng (3-tier subnet model) như AWS:

- ▶ **Tầng công cộng (Public subnet)** để tiếp nhận truy cập từ Internet
- ▶ **Tầng ứng dụng (Private Application subnet)** để xử lý nghiệp vụ
- ▶ **Tầng cơ sở dữ liệu (DB subnet)** đảm bảo cách ly và bảo mật dữ liệu nhân sự



Hình 7 Chi tiết Virtual Subnet và các thành phần trong mỗi tầng

Chi tiết các thành phần trong mỗi tầng:

► **Lớp bảo mật đầu vào**

- **Cloudflare** bảo vệ khỏi tấn công từ Internet, che giấu hạ tầng thực.
- **Application Gateway + Web Application Firewall (WAF)** là tuyến đầu tiếp nhận lưu lượng người dùng, lọc và bảo vệ khỏi các lỗ hổng bảo mật (SQLi, XSS...).
- **Azure Active Directory (Azure AD)** hỗ trợ xác thực và phân quyền người dùng, tích hợp đăng nhập một lần (SSO) và bảo mật đa lớp (MFA).
- **Chính sách truy cập mạng riêng (VPN/IP nội bộ)**: Cho phép cấu hình chỉ truy cập từ IP công ty hoặc qua VPN bảo mật (Azure VPN Gateway).

► **Tầng ứng dụng (Application Tier – Private Subnet)**

- Hệ thống HRM được triển khai trên **Virtual Machine (VM)** cài đặt Windows + IIS, chạy các dịch vụ ứng dụng (frontend Angular + backend .NET Core).
- Các máy chủ được đặt trong **Private Subnet**, cách ly hoàn toàn khỏi Internet, chỉ được truy cập từ tầng WAF hoặc thông qua Bastion Host.
- Các máy chủ được bảo vệ bởi **Network Security Group (NSG)** – giới hạn lưu lượng vào/ra chi tiết theo IP, port, giao thức.

► **Tầng cơ sở dữ liệu (Database Tier – DB Subnet)**

- Dữ liệu nhân sự được lưu trữ trên **Azure SQL Server** trong vùng riêng biệt (Tier 3 – Private Subnet).
- Bảo mật bởi NSG và chỉ cho phép truy cập từ VM ứng dụng nội bộ.
- Hỗ trợ sao lưu tự động, mã hóa dữ liệu và phục hồi theo thời gian (point-in-time restore).
- Có thể thiết lập **Geo-Replication** cho site dự phòng hoặc mở rộng HA khi cần thiết.

► **Giám sát, nhật ký & hiệu năng**

- **Azure Monitor** thu thập chỉ số hoạt động: CPU, RAM, dung lượng, băng thông...
- **Log Analytics Workspaces** lưu trữ log truy cập, thao tác người dùng, lỗi hệ thống.

- ▶ **Azure Monitor Dashboard** trực quan hóa dữ liệu hoạt động qua biểu đồ – giúp quản trị viên dễ theo dõi, cảnh báo sớm nếu có bất thường.
- ▶ **Khả năng mở rộng & linh hoạt**
 - ▶ Có thể dễ dàng mở rộng **số lượng VM** trong lớp ứng dụng (scale-out), hoặc nâng cấp cấu hình từng VM (scale-up).
 - ▶ Tách biệt hoàn toàn tài nguyên giữa các khách hàng (Single-Tenant), đảm bảo không bị ảnh hưởng bởi hệ thống khác.
 - ▶ Tùy chọn tích hợp với **Azure Functions** hoặc dịch vụ container (AKS) nếu mở rộng theo hướng microservices.

2.3. Yêu cầu Server để chạy ứng dụng (không bao gồm Firewall và DR Site dự phòng)

#	Thông tin người dùng: Số lượng nhân viên: <= 1000 Số lượng người dùng HR Users: 01 – 05 Users Số lượng Portal Users: 20% User đồng thời
	Phương án đầu tư 03 Server tham khảo mô hình (<i>Database Server & Application Server tách biệt</i>) Tham khảo mô hình: Mô hình cơ bản
1	Server 1 Proxy (option) - CPU: 4 Core, Ram 8 GB, SSD 50GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Anti Virus for Servers
2	Server Application + database - CPU: 8 Core, Ram 32 GB, SSD 256GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Anti Virus for Servers

#	Thông tin người dùng: Số lượng nhân viên: 1000 -3000 Số lượng người dùng HR Users: 01 – 30 Users Số lượng Portal Users: 20% User đồng thời
	Phương án đầu tư 03 Server tham khảo mô hình (<i>Database Server & Application Server tách biệt</i>) Tham khảo mô hình: Mô hình tiêu chuẩn
1	Server 1 Proxy (option) - CPU: 4 Core, Ram 8 GB, SSD 50GB - MS Windows Server License (<i>Version từ 2016 trở lên</i>) - Anti Virus for Servers
2	Server Application - CPU: 10 Core, Ram 64 GB, SSD 256GB - MS Windows Server License (<i>Version từ 2016 trở lên</i>) - Anti Virus for Servers
3	Server Database Server - CPU: 8 Core, Ram 64 GB, SSD 256GB - MS Windows Server License (<i>Version từ 2016 trở lên</i>) - Microsoft SQL Server Standard 2019 - Anti Virus for Servers

#	Thông tin người dùng: Số lượng nhân viên: 3000 - 6000 Số lượng người dùng HR Users: 01 – 30 Users Số lượng Portal Users: 20% User đồng thời
	Phương án đầu tư 03 Server tham khảo mô hình (<i>Database Server & Application Server tách biệt</i>) Tham khảo mô hình: Mô hình tiêu chuẩn
1	Server 1 Proxy (option) - CPU: 4 Core, Ram 8 GB, SSD 50GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Anti Virus for Servers
2	Server Application - CPU: 12 Core, Ram 64GB, SSD 500GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Anti Virus for Servers
3	Server Database Server - CPU: 10 Core, Ram 64 GB, SSD 256GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Microsoft SQL Server Standard 2019 - Anti Virus for Servers

#	Thông tin người dùng: Số lượng nhân viên: 6000 - 8000 Số lượng người dùng HR Users: 01 – 30 Users Số lượng Portal Users: 20% User đồng thời
	Phương án đầu tư 03 Server tham khảo mô hình (<i>Database Server & Application Server tách biệt</i>) Tham khảo mô hình: Mô hình mở rộng
1	Server 1 Proxy (option) - CPU: 4 Core, Ram 8 GB, SSD 50GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Anti Virus for Servers
2	Server Application 1 - CPU: 12 Core, Ram 64GB, SSD 500GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Anti Virus for Servers
3	Server Application 2 - CPU: 12 Core, Ram 64GB, SSD 500GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Anti Virus for Servers
4	Server Database Server 1 - CPU: 12 Core, Ram 96GB, SSD - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Microsoft SQL Server Standard 2019 - Anti Virus for Servers
5	Server Database Server 2 - CPU: 12 Core, Ram 96GB, SSD - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Microsoft SQL Server Standard 2019 - Anti Virus for Servers

#	Thông tin người dùng: Số lượng nhân viên: 8000 - 12000 Số lượng người dùng HR Users: 01 – 30 Users Số lượng Portal Users: 20% User đồng thời
	Phương án đầu tư 03 Server tham khảo mô hình (<i>Database Server & Application Server tách biệt</i>) Tham khảo mô hình: Mô hình mở rộng
1	Server 1 Proxy (option) - CPU: 4 Core, Ram 8 GB, SSD 50GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Anti Virus for Servers
2	Server Application 1 - CPU: 16 Core, Ram 96GB, SSD 500GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Anti Virus for Servers
3	Server Application 2 - CPU: 16 Core, Ram 96GB, SSD 500GB - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Anti Virus for Servers
4	Server Database Server 1 - CPU: 12 Core, Ram 124GB, SSD - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Microsoft SQL Server Standard 2019 - Anti Virus for Servers
5	Server Database Server 2 - CPU: 12 Core, Ram 124GB, SSD - MS Windows Server License (<i>Version từ 2019 trở lên</i>) - Microsoft SQL Server Standard 2019 - Anti Virus for Servers

Ghi chú

- ▶ Live Class: Nên sử dụng Third party: Webex, Zoom Meet, MS Team.. để tối ưu buổi chất lượng meeting
- ▶ Video: Đối với video private thì sử dụng trực tiếp trên hệ thống (Network trung bình: 5Mbps/User truy cập đồng thời). Đối với video public thì nên sử dụng third party như Youtube (nhúng lên hệ thống và có hỗ trợ hạn chế User truy cập link Youtube từ LMS) nhằm tránh phải triển khai băng thông Network quá lớn.
- ▶ Hệ thống phần mềm VnResource LMS Pro có thể chạy được trên các hệ thống Server vật lý, ảo hoặc Cloud... Quý công ty có thể lựa chọn phương án tốt nhất.
- ▶ Server dựa trên quy mô đồng thời tại mỗi thời điểm thông thường 30%
- ▶ Định kỳ 06 tháng 1 lần, cấu hình Server sẽ được đánh giá mức độ sử dụng và mức độ gia tăng dữ liệu thực tế để có phương án điều chỉnh phù hợp.

3. Mô hình dữ liệu & tích hợp

Hệ thống HRM cần một kiến trúc dữ liệu vững chắc và khả năng tích hợp linh hoạt với các hệ thống khác trong doanh nghiệp. Phần này mô tả **cơ sở dữ liệu** được sử dụng và cách thức tích hợp hệ thống với các ứng dụng bên ngoài.

3.1. Cơ sở dữ liệu

Cơ sở dữ liệu chính của hệ thống HRM sử dụng Microsoft SQL Server / PostgreSQL. Đây là nơi lưu trữ toàn bộ dữ liệu nhân sự: thông tin nhân viên, phòng ban, chấm công, lương thưởng, hồ sơ, v.v. SQL Server được lựa chọn do khả năng xử lý giao dịch cao, tính ổn định và hỗ trợ tốt cho các nghiệp vụ phức tạp của HRM.

3.1.1. Vai trò

CSDL SQL Server đóng vai trò trung tâm, đảm bảo **tính nhất quán dữ liệu** giữa các phân hệ (ví dụ module chấm công, nghỉ phép, tính lương đều dùng chung một nguồn dữ liệu nhân viên). Mọi thao tác của người dùng qua ứng dụng (như cập nhật hồ sơ, phê duyệt đơn từ) cuối cùng đều được ghi vào SQL Server, đảm bảo lưu vết và truy xuất sau này.

3.1.2. Sao lưu định kỳ (Backup)

Toàn bộ CSDL HRM được **sao lưu (backup)** thường xuyên để đảm bảo an toàn dữ liệu. Chính sách sao lưu có thể đặt ra như sau: **backup đầy đủ hàng ngày** (full backup mỗi đêm) và **backup gia tăng mỗi giờ** (differential/incremental) để ghi nhận những thay đổi mới. Các bản backup được lưu trữ an toàn (ví dụ: trên một máy chủ lưu trữ file nội bộ, hoặc trên storage cloud) và được giữ trong thời gian nhất định (ví dụ: lưu trữ bản full backup tuần tại site DR). Quy trình khôi phục cũng được thử nghiệm định kỳ để đảm bảo backup có thể phục hồi khi cần. Nhờ đó, trong trường hợp lỗi dữ liệu do phần mềm hoặc con người (ví dụ lỡ xóa nhầm dữ liệu), đội ngũ kỹ thuật có thể nhanh chóng **restore** lại từ bản sao lưu gần nhất, giảm thiểu gián đoạn nghiệp vụ.

Loại sao lưu	Tần suất	Nội dung được sao lưu	Mục đích	Thời gian lưu giữ
Daily Backup	Hằng ngày (ban đêm)	- Toàn bộ cơ sở dữ liệu (Full Backup)- Toàn bộ file tài liệu nhân sự- Snapshot hệ thống (nếu có thay đổi code/cấu hình)	Phục hồi nhanh trong trường hợp lỗi nghiệp vụ, thao tác nhầm	7 – 14 ngày
Weekly Backup	Mỗi Thứ Bảy/Chủ Nhật	- Toàn bộ DB + file hệ thống- Mã nguồn ứng dụng (nếu có update)	Đảm bảo khôi phục toàn bộ trong tuần, làm mốc dài hơn Daily	1 – 2 tháng
Monthly Backup	Mỗi tháng	- DB cuối tháng (chốt kỳ công, lương, nghỉ phép)- Cấu hình hệ thống	Đáp ứng kiểm tra lịch sử và đối chiếu kế toán, tài chính	6 – 12 tháng
Yearly Archive	Cuối năm tài chính	- Snapshot toàn hệ thống: DB, file, log, audit trail- Tình trạng nhân sự cuối năm	Lưu trữ phục vụ thanh tra, kiểm toán, pháp lý, nội bộ	3 – 10 năm

Bảng 2 Thông tin về các chiến lược sao lưu của hệ thống HRM

3.2. Tích hợp hệ thống

Hệ thống HRM được thiết kế mở, hỗ trợ **tích hợp** với nhiều hệ thống và dịch vụ khác nhau trong doanh nghiệp nhằm tạo nên một hệ sinh thái CNTT thống nhất. Việc tích hợp cho phép các ứng dụng trao đổi dữ liệu tự động với nhau, giảm nhập liệu thủ công và đảm bảo thông tin nhất quán. **Phương thức tích hợp** và **các hệ thống tích hợp** cụ thể như sau:

3.2.1. Phương thức tích hợp

Hệ thống hỗ trợ nhiều cơ chế tích hợp hiện đại:

- ▶ **API RESTful:** HRM cung cấp các **API đầu ra** (RESTful API) để các ứng dụng khác (như cổng thông tin, mobile app, hệ thống chấm công ngoài, v.v.) có thể truy vấn hoặc cập nhật dữ liệu nhân sự một cách bảo mật. Dữ liệu truyền theo định dạng JSON qua giao thức HTTP/HTTPS. Đồng thời, HRM có thể gọi **API của hệ thống khác** để đồng bộ thông tin (ví dụ gọi API của hệ thống kế toán để lấy dữ liệu lương).
- ▶ **Webhook:** Hệ thống cho phép thiết lập các **webhook** – khi có sự kiện quan trọng xảy ra (ví dụ: tạo mới nhân viên, duyệt nghỉ phép, phê duyệt lương), HRM sẽ gửi một thông báo (HTTP POST) theo thời gian thực đến URL đã cấu hình của hệ thống khác. Điều này giúp các hệ thống liên quan cập nhật ngay lập tức, chẳng hạn gửi thông báo qua hệ thống Portal nội bộ hoặc cập nhật trạng thái nhân viên sang phần mềm chấm công.
- ▶ **SSO (Single Sign-On):** Hỗ trợ tích hợp **đăng nhập một lần** với hệ thống quản lý danh tính chung của doanh nghiệp. Ví dụ: nhân viên đã đăng nhập vào cổng thông tin nội bộ có thể truy cập HRM mà không cần đăng nhập lại. HRM có thể tích hợp SSO qua các giao thức phổ biến như **OpenID Connect** hoặc **OAuth2**, thường kết nối với dịch vụ AD/LDAP (Active Directory) của doanh nghiệp. Điều này tăng tính tiện lợi và bảo mật, vì quản lý tập trung tài khoản người dùng.
- ▶ **OAuth2:** Hỗ trợ giao thức **OAuth 2.0** để các ứng dụng bên thứ ba có thể được ủy quyền truy cập một phần dữ liệu HRM một cách an toàn. **Ví dụ:** một ứng dụng di động có thể sử dụng OAuth2 để lấy token truy cập vào API HRM (theo phạm vi được cho phép). OAuth2 cũng hữu ích khi tích hợp với nền tảng bên ngoài (như dịch vụ chấm công đám mây, hệ thống tuyển dụng) mà vẫn đảm bảo không lộ thông tin đăng nhập gốc của người dùng.

Cơ chế chung:

- ▶ Có hỗ trợ ghi log lịch sử tích hợp
- ▶ Có chức năng đồng bộ lại khi có sự cố

3.2.2. Các hệ thống tích hợp

Giải pháp HRM có thể kết nối và trao đổi dữ liệu với nhiều hệ thống nghiệp vụ khác trong tổ chức:

- ▶ **Hệ thống CRM/ERP hoặc Tài chính/Kế toán:** Tích hợp với phần mềm kế toán hoặc ERP tài chính để đồng bộ dữ liệu liên quan đến **lương thưởng, thuế**. **Ví dụ:** cuối tháng, module tính lương của HRM có thể xuất dữ liệu bảng lương sang hệ thống kế toán để thực hiện trả lương và hạch toán chi phí nhân sự. Ngược lại, nếu hệ thống kế toán có thông tin về thuế thu nhập cá nhân, bảo hiểm, HRM cũng có thể lấy về để hiển thị cho nhân viên.
- ▶ **Hệ thống Quản lý nhân sự khác (HRM/HRIS khác):** Trong trường hợp doanh nghiệp đã có sẵn một phần mềm nhân sự hoặc các module nhân sự khác, giải pháp HRM mới có thể tích hợp hai chiều để trao đổi dữ liệu. **Ví dụ:** tích hợp với hệ thống chấm công máy vân tay – HRM nhận dữ liệu quét thẻ từ máy chấm công, hoặc ngược lại gửi thông tin lịch làm việc từ HRM sang.

- ▶ **Email/SMS Gateway:** Hệ thống HRM tích hợp với dịch vụ email và SMS để gửi thông báo. **Ví dụ:** khi phòng nhân sự duyệt một quyết định, hệ thống tự động gửi **email** thông báo đến nhân viên liên quan. Hoặc khi nhân viên quên mật khẩu, hệ thống gửi **SMS OTP** để đặt lại mật khẩu. Việc tích hợp có thể thông qua SMTP (đối với email) và API của nhà cung cấp SMS. Các thông điệp (nội dung email/SMS) được thiết lập sẵn và kích hoạt bởi các sự kiện trong HRM (như nghỉ phép được duyệt, thông báo đào tạo, nhắc nhở cập nhật thông tin,...).

4. Yêu cầu phi chức năng

Bên cạnh các chức năng nghiệp vụ, hệ thống HRM được thiết kế để đáp ứng các yêu cầu phi chức năng quan trọng, đảm bảo **hiệu suất, khả năng mở rộng, dự phòng** và **giám sát**. Những yêu cầu này được làm rõ bằng các ví dụ thực tế, giúp khách hàng dễ hình dung

4.1. Hiệu suất

Mục tiêu: Hệ thống phải phản hồi nhanh, đảm bảo trải nghiệm mượt mà, không gián đoạn, kể cả khi có hàng nghìn người dùng truy cập cùng lúc.

Biện pháp & Cơ chế:

- ▶ Ứng dụng được tối ưu để **phản hồi nhanh $\leq 2-3$ giây** cho các thao tác phổ biến (truy vấn hồ sơ, tra cứu phiếu lương, phê duyệt đơn,...).
- ▶ **Dữ liệu tĩnh** hoặc ít thay đổi như danh mục phòng ban, chức danh, cấu hình hệ thống... được cache lại (Redis Cache hoặc memory cache) giúp giảm truy vấn cơ sở dữ liệu.
- ▶ Các thao tác truy vấn lớn được phân trang (pagination) để giảm tải xử lý.
- ▶ Ứng dụng sử dụng **stored procedure** và **chỉ mục (index)** để tăng tốc độ xử lý truy vấn trong SQL Server.
- ▶ Áp dụng **kỹ thuật nén dữ liệu** và truyền tải hiệu quả (HTTP compression, lazy loading frontend).

Ví dụ thực tế:

Trong kỳ tính lương cuối tháng, 500-1000 nhân viên đồng thời truy cập để xem phiếu lương. Hệ thống vẫn đảm bảo mỗi nhân viên nhận được kết quả trong vòng 2 giây, không bị đứng hoặc tải lại nhiều lần.

4.2. Khả năng mở rộng (Scalability)

Mục tiêu: Hệ thống cần linh hoạt để mở rộng về người dùng, dữ liệu hoặc chức năng mà không ảnh hưởng hiệu năng hoặc phải sửa code lớn.

Biện pháp & Cơ chế:

- ▶ **Mở rộng ngang (Horizontal Scaling):** Cho phép thêm nhiều máy chủ ứng dụng, các request được phân phối bởi Load Balancer.
- ▶ **Mở rộng dọc (Vertical Scaling):** Có thể nâng cấp cấu hình máy chủ hiện tại (CPU, RAM, ổ cứng) khi cần mà không thay đổi mã nguồn.
- ▶ **Kiến trúc Stateless:** Nhờ sử dụng **JWT Token**, các phiên làm việc của người dùng không bị ràng buộc vào một máy chủ cụ thể → cho phép load balancing tự do.

- ▶ Hệ thống **không bị giới hạn bởi số lượng người dùng tăng lên**: mỗi khi tăng quy mô doanh nghiệp, chỉ cần cấu hình lại hạ tầng mà không cần viết lại ứng dụng.
- ▶ Có thể áp dụng **microservices** trong tương lai để mở rộng từng chức năng độc lập.

Ví dụ thực tế:

Một doanh nghiệp từ 800 nhân viên tăng lên 1.600 nhân viên trong 6 tháng, chỉ cần thêm 1 máy chủ ứng dụng và nâng cấp ổ cứng CSDL – mà không cần sửa đổi phần mềm hay làm gián đoạn hệ thống.

4.3. Dự phòng và khôi phục thảm họa (Availability & Disaster Recovery – DR)

Mục tiêu: Hệ thống luôn sẵn sàng, không bị ngắt quãng kể cả khi có lỗi phần cứng, sự cố kỹ thuật hoặc thiên tai.

Biện pháp & Cơ chế:

- ▶ Triển khai **HA (High Availability)**: ứng dụng và CSDL được chạy ở dạng cụm (cluster), có node chính và node dự phòng.
- ▶ Khi 1 server gặp sự cố, Load Balancer **tự động loại bỏ server lỗi** và chuyển toàn bộ người dùng sang server còn lại.
- ▶ **Cơ sở dữ liệu** được nhân bản sang một node phụ (Passive/Replica), dữ liệu được đồng bộ thời gian thực (Always-On).
- ▶ Hệ thống được backup định kỳ (full backup hàng ngày/tuần, tháng,...) và lưu trữ trên vùng độc lập.
- ▶ Có thể **khôi phục toàn hệ thống trong vài giờ** nếu có cháy nổ, thiên tai tại trung tâm dữ liệu chính.

Ví dụ thực tế:

Nếu phòng máy chủ chính bị sự cố (chập điện, cháy ổ cứng), đội kỹ thuật có thể chuyển toàn bộ hệ thống sang site DR với bản backup mới nhất, giúp doanh nghiệp tiếp tục hoạt động chỉ sau 1-2 giờ.

4.4. Giám sát & Cảnh báo (Monitoring & Alerting)

Mục tiêu: Theo dõi hệ thống liên tục, phát hiện sự cố sớm để xử lý trước khi ảnh hưởng đến người dùng.

Biện pháp & Cơ chế:

- ▶ Ghi lại **log truy cập, log thao tác, lỗi phần mềm** qua hệ thống Logging trung tâm (Log File Server).
- ▶ Có màn hình hiển thị thông tin, giúp quản trị viên theo dõi tình trạng chung toàn hệ thống.

Ví dụ thực tế:

Khi hệ thống có một service bị lỗi liên tục (thí dụ: API nghỉ phép trả lỗi 500), hệ thống giám sát tự động sẽ ghi log chi tiết lỗi. Đội kỹ thuật có thể xử lý chỉ trong vài phút, trước khi người dùng gặp ảnh hưởng nghiêm trọng. Các yêu cầu phi chức năng được tích hợp **ngay từ kiến trúc hệ thống**, không chỉ là “tính năng thêm vào” mà là **cốt lõi để đảm bảo tính bền vững**:

Nhóm yêu cầu	Giá trị mang lại cho doanh nghiệp
Hiệu suất	Trải nghiệm mượt mà, không bị gián đoạn, phản hồi nhanh

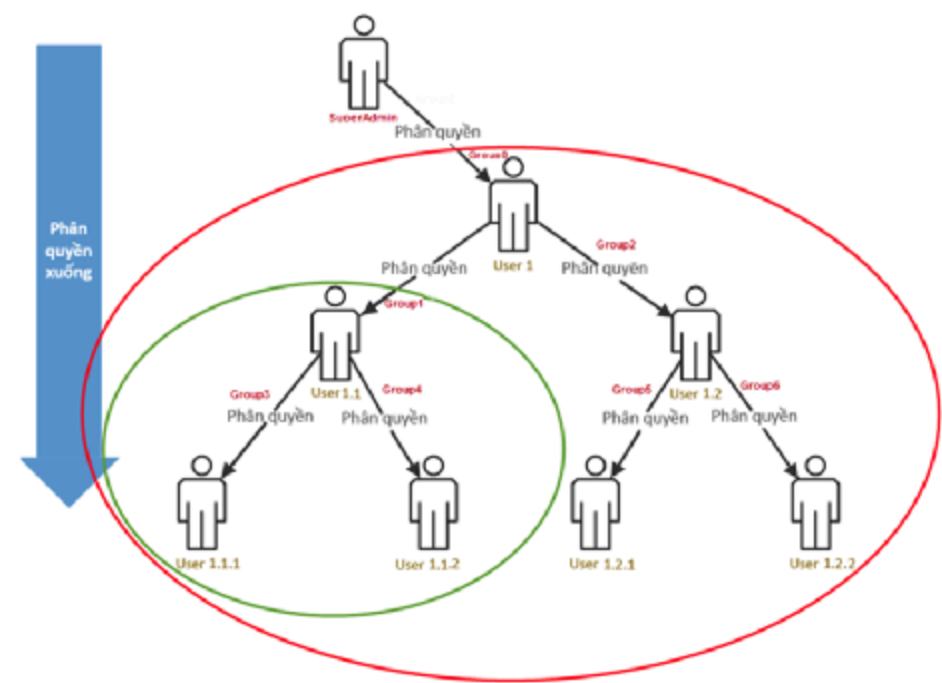
Nhóm yêu cầu	Giá trị mang lại cho doanh nghiệp
Mở rộng	Không bị giới hạn quy mô – dễ dàng phát triển lâu dài
Dự phòng & DR	Hoạt động liên tục, an toàn, không mất dữ liệu
Giám sát & Cảnh báo	Chủ động, phòng ngừa trước sự cố – giảm thiểu rủi ro

5. Kiến trúc bảo mật

Hệ thống HRM được thiết kế với tư duy "**bảo mật nhiều lớp**" (**defense in depth**), nhằm bảo vệ toàn diện dữ liệu nhân sự – một trong những tài sản nhạy cảm nhất của doanh nghiệp. Mỗi lớp từ người dùng cho đến hạ tầng đều được kiểm soát chặt chẽ.

5.1. Phân quyền chi tiết theo vai trò (Role-Based Access Control – RBAC)

Ví dụ chi tiết về nhóm quyền



Mô tả nhóm quyền(tìm kiếm/chỉnh sửa) theo hình ở trên

- User1 được quyền thấy tất cả các quyền thuộc vùng khung màu đỏ
- Group0: chỉ hiển thị **tìm kiếm** (không cho phép chỉnh sửa)
 - Group1,Group2,Group3,Group4,Group5,Group6: cho phép **tìm kiếm và chỉnh sửa**

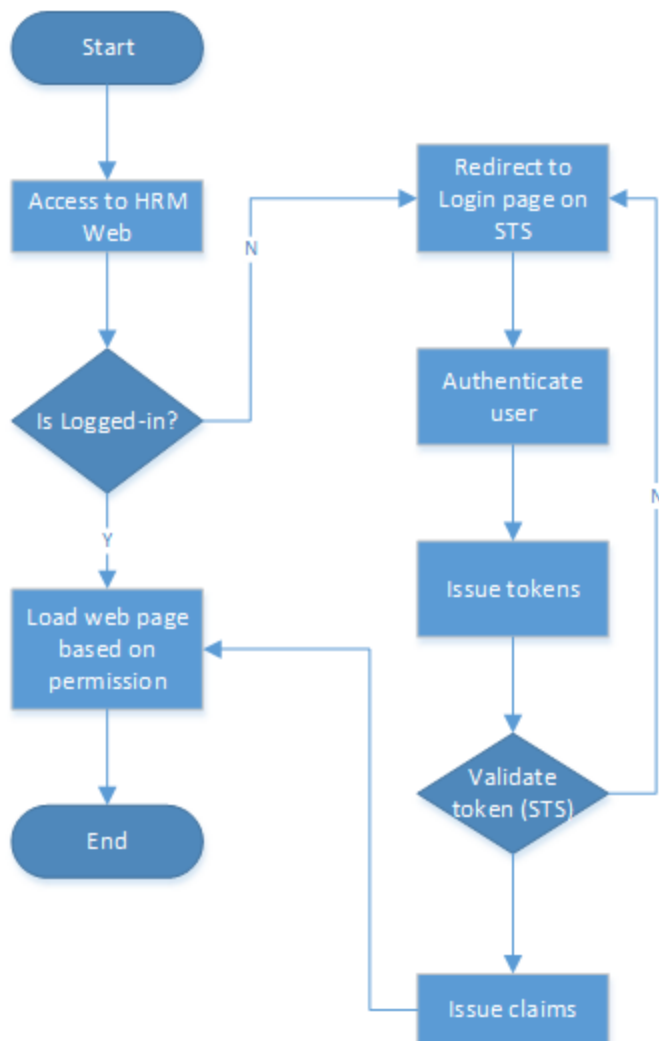
- User1.1 chỉ nhìn thấy các quyền thuộc vùng màu xanh lá
- Group1: chỉ hiển thị **tìm kiếm** (không cho phép chỉnh sửa)
 - Group3,Group4: cho phép **tìm kiếm và chỉnh sửa**

Hình 9 Cách mà hệ thống phân quyền đến người dùng

- ▶ Mỗi người dùng trong hệ thống đều được gán **vai trò cụ thể** (như: nhân viên, trưởng phòng, giám đốc, HR, IT Admin).
- ▶ Mỗi vai trò được cấu hình chi tiết các **quyền truy cập** đến từng phân hệ và hành động cụ thể (xem, thêm, sửa, xóa...).
- ▶ Hệ thống cho phép **tuỳ chỉnh vai trò** theo đặc thù từng tổ chức (vd: tách riêng vai trò kế toán tiền lương và nhân sự tổng hợp).
- ▶ Áp dụng nguyên tắc **"ít quyền nhất" (least privilege)**: chỉ cấp đúng và đủ quyền cần thiết cho từng vị trí.

Ví dụ: Nhân viên A chỉ được xem hồ sơ cá nhân, gửi yêu cầu nghỉ phép và theo dõi đơn của mình – không thể xem hồ sơ người khác hoặc danh sách toàn bộ nhân viên.

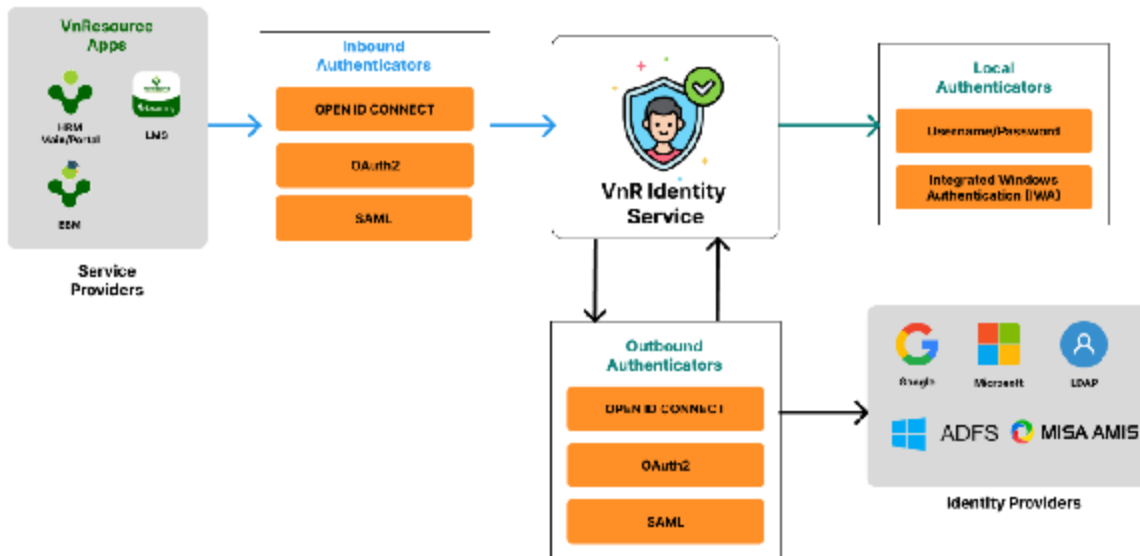
5.2. Authentication/Authorization



Hình 10 Sơ đồ mô tả cách mà hệ thống Authentication/Authorization

- ▶ Hệ thống sử dụng service HRM Identity để xác thực các ứng dụng trước khi user được phép truy cập đến ứng dụng/tài nguyên của hệ thống.

- ▶ Khi đăng nhập (xác thực) thành công, hệ thống phát hành một **token JWT** cho người dùng, chứa thông tin mã hóa như ID, vai trò, thời hạn token.
- ▶ Token này được gửi kèm theo mỗi yêu cầu gọi API → giúp hệ thống **xác thực và phân quyền nhanh chóng, không cần lưu session**.
- ▶ Giúp tăng khả năng **mở rộng hệ thống** (stateless) và bảo vệ khỏi việc đánh cắp phiên đăng nhập (session hijacking).
- ▶ Token có thể bị thu hồi nếu phát hiện bất thường hoặc khi người dùng đăng xuất.



Hình 11 Mô tả cách mà các ứng dụng HRM xác thực trước khi truy cập vào hệ thống/tài nguyên

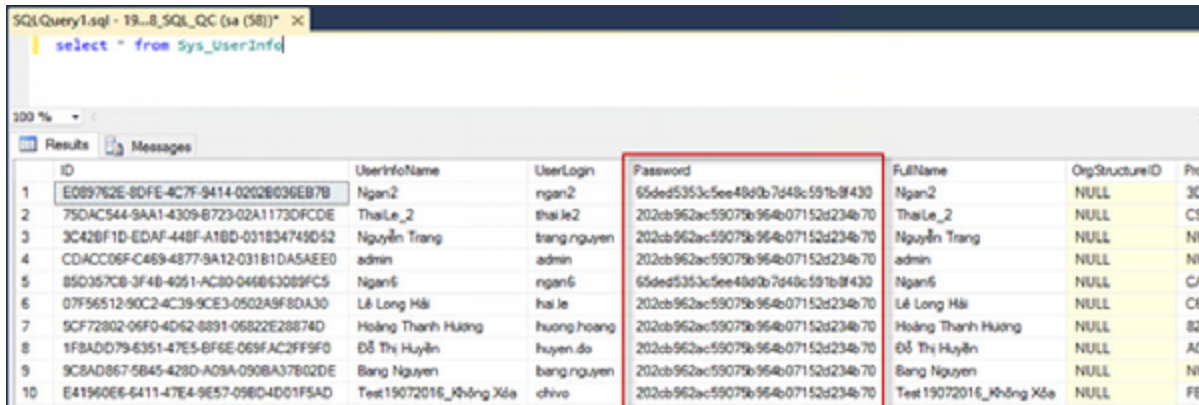
5.3. Chính sách bảo mật Web: CORS, XSS, CSRF

- ▶ **CORS (Cross-Origin Resource Sharing):** Chỉ cho phép các domain cụ thể (vd: portal nội bộ, app mobile công ty) truy cập API hệ thống. Chặn mọi nguồn không hợp lệ.
- ▶ **Chống XSS:** Tất cả dữ liệu nhập từ người dùng đều được lọc và mã hóa trước khi hiển thị trở lại, tránh chèn mã độc vào trình duyệt.
- ▶ **Chống CSRF:** Với các thao tác quan trọng (sửa hồ sơ, gửi đơn, duyệt...), hệ thống yêu cầu token CSRF để xác minh chính chủ thao tác – tránh bị ép gửi lệnh ngoài ý muốn.
- ▶ Tất cả truyền thông giữa client và server được **mã hóa SSL (HTTPS)** đảm bảo không ai có thể đọc lén hoặc giả mạo nội dung.

5.4. Mã Hóa Dữ Liệu:

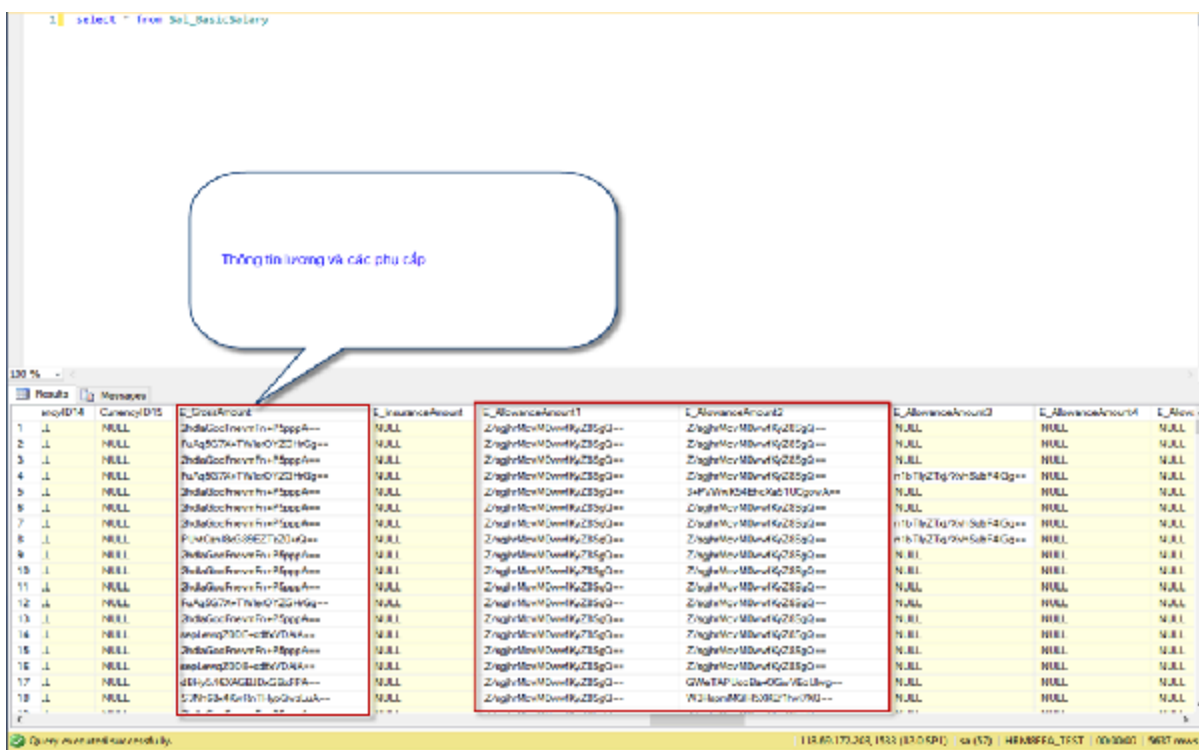
- ▶ **Mã Hóa Dữ Liệu Truyền Tải:** Tất cả dữ liệu truyền tải giữa máy khách và máy chủ đều được mã hóa bằng giao thức HTTPS sử dụng TLS 1.2 (Transport Layer Security) để đảm bảo rằng dữ liệu không bị nghe lén hoặc thay đổi trong quá trình truyền tải.
- ▶ **Mã Hóa Dữ Liệu Lưu Trữ:** Dữ liệu nhạy cảm như mật khẩu được mã hóa bằng các thuật toán mã hóa mạnh mẽ như AES (Advanced Encryption Standard) trước khi lưu trữ trong cơ sở dữ liệu. Mật khẩu người dùng được

băm (hashed) và kèm theo muối (salt) bằng các thuật toán như bcrypt để tăng cường bảo mật, đảm bảo rằng ngay cả khi cơ sở dữ liệu bị xâm nhập, mật khẩu vẫn an toàn.



ID	UserInfoName	UserLogin	Password	FullName	OrgStructureID	Prot
1	Ngan2	ngan2	65ded5353c5ee48a0b7d48c591b8f430	Ngan2	NULL	30
2	ThaiLe_2	thaiLe2	202cb962ac59075b964b07152d234b70	ThaiLe_2	NULL	C9
3	Nguyễn Trang	trang.nguyen	202cb962ac59075b964b07152d234b70	Nguyễn Trang	NULL	NU
4	admin	admin	202cb962ac59075b964b07152d234b70	admin	NULL	NU
5	Ngan6	ngan6	65ded5353c5ee48a0b7d48c591b8f430	Ngan6	NULL	CA
6	Lê Long Hải	hai.le	202cb962ac59075b964b07152d234b70	Lê Long Hải	NULL	CS
7	Hoàng Thanh Hương	huong.hoang	202cb962ac59075b964b07152d234b70	Hoàng Thanh Hương	NULL	S2
8	Đỗ Thị Huyền	huyen.do	202cb962ac59075b964b07152d234b70	Đỗ Thị Huyền	NULL	A0
9	Bang Nguyen	bang.nguyen	202cb962ac59075b964b07152d234b70	Bang Nguyen	NULL	NU
10	Test19072016_Không Xsá	chivo	202cb962ac59075b964b07152d234b70	Test19072016_Không Xsá	NULL	FE

Hình 12 Mã hóa mật khẩu tài khoản



empID	CurrentDTIS	C_GrossAmount	C_InuranceAmount	C_AlvanceAmount1	C_AlvanceAmount2	C_AlvanceAmount3	C_AlvanceAmount4	C_AlvanceAmount5
1	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
2	NULL	FuAg9C7W+TbVnQY221hGg==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
3	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
4	NULL	FuAg9C7W+TbVnQY221hGg==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
5	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
6	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
7	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
8	NULL	FuAg9C7W+TbVnQY221hGg==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
9	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
10	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
11	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
12	NULL	FuAg9C7W+TbVnQY221hGg==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
13	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
14	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
15	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
16	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
17	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL
18	NULL	2hdaGocfnevrIn+7pppA==	NULL	2hdaGocfnevrIn+7pppA==	2hdaGocfnevrIn+7pppA==	NULL	NULL	NULL

Hình 13 Mã hóa thông tin lương

5.5. Đăng nhập đa yếu tố (MFA – Multi-Factor Authentication)

- ▶ Hệ thống hỗ trợ tùy chọn **MFA (xác thực 2 bước)**: ngoài mật khẩu, người dùng cần nhập thêm mã OTP từ email, SMS hoặc ứng dụng xác thực.
- ▶ Có thể bật MFA bắt buộc cho các vai trò quan trọng như quản trị hệ thống, giám đốc nhân sự, kế toán trưởng.
- ▶ Cơ chế giúp **bảo vệ tài khoản kể cả khi mật khẩu bị lộ**.

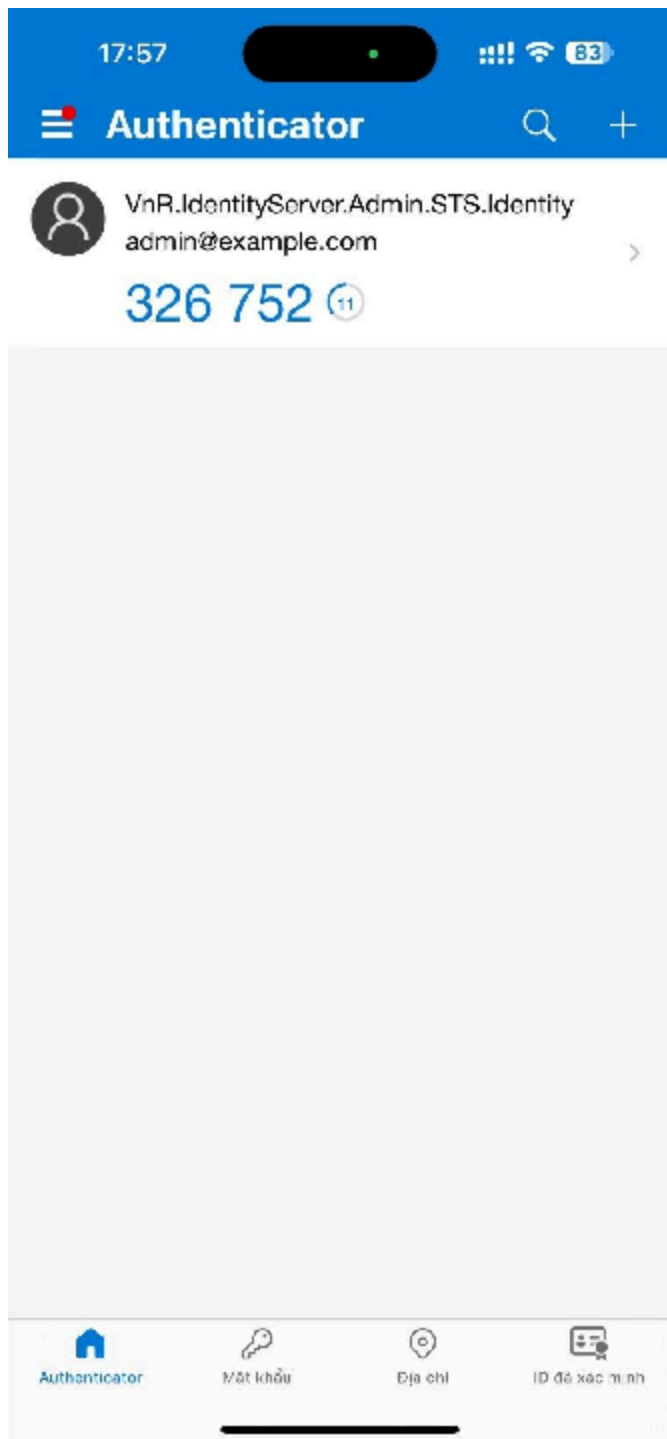


Hình 14 SSO với tài khoản Microsoft

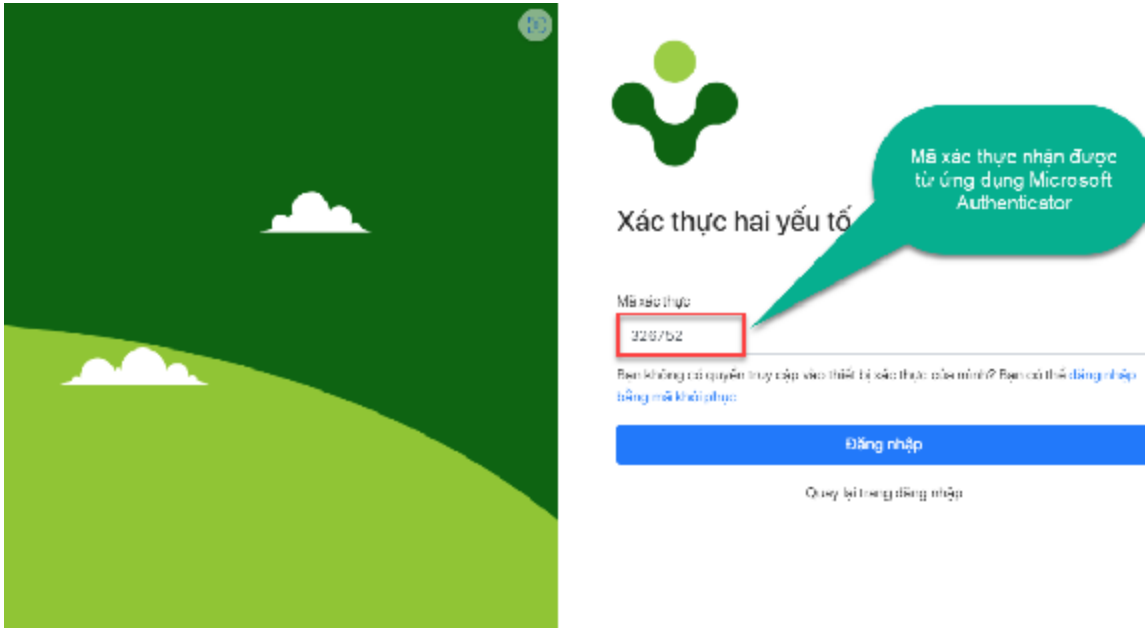


Hình 15 Xác thực 2 yếu tố





Hình 16 Sử dụng ứng dụng xác thực của Microsoft Authenticator



Hình 17 Quá trình nhập mã xác thực lấy từ ứng dụng Microsoft Authenticator

5.6. Nhật ký truy cập & giám sát bảo mật (Audit Logging)

- ▶ Hệ thống ghi lại chi tiết:
 - ▶ Lịch sử đăng nhập (thời gian, IP, thiết bị).
 - ▶ Các thao tác dữ liệu nhạy cảm (thêm/sửa/xóa nhân viên, tính lương, phân quyền).
 - ▶ Lỗi phát sinh, cảnh báo truy cập bất thường.
- ▶ Log không thể bị sửa đổi bởi người dùng thường.
- ▶ Có thể tích hợp log vào hệ thống giám sát bảo mật chung của tổ chức (SIEM, CloudWatch, Azure Sentinel...).

Lợi ích: Giúp kiểm tra truy vết khi xảy ra sự cố, đảm bảo trách nhiệm, minh bạch trong thao tác nội bộ.